



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Normativa de Ciberseguridad

TEMA 3

Legislación para el cumplimiento de la responsabilidad penal
Alberto Diéguez Álvarez

Tabla de contenido

Caso práctico.....	3
Apartado 1: Catálogo de Ciber-Riesgos Penales.	4
Apartado 2: Matriz de Riesgo y Controles Mitigantes.....	5
Apartado 3: Adecuación a la Ley 2/2023 y NIS2.	6

Caso práctico



[isttic](#). Antena de Telecomunicaciones (CC BY-NC-SA)

ACME S.A. sigue siendo una "Telco" líder con 300.000 clientes, presencia internacional y contratos con embajadas y banca. Su infraestructura física es moderna y sostenible.

Estamos en el año en curso. La entrada en vigor de la Ley 2/2023 (Protección del Denunciante) y la transposición de la Directiva NIS2 han cambiado las reglas del juego.

El Consejo de Administración de ACME está muy nervioso. Han recibido una notificación legal advirtiéndoles que, al ser una empresa de telecomunicaciones, ahora son considerados "Entidad Esencial". Además, el Director General ha leído que, bajo la nueva normativa, él podría responder con su patrimonio personal o ser inhabilitado si ocurre un ciberataque grave por falta de diligencia.

Como Responsable de Seguridad y Cumplimiento (CISO/Compliance Officer), se te ha encargado actualizar el "Mapa de Riesgos Penales" y definir los requisitos para las nuevas obligaciones legales.

¿Qué te pedimos que hagas?

Debes elaborar un informe técnico para la Dirección dando respuesta a los siguientes tres apartados:

Apartado 1: Catálogo de Ciber-Riesgos Penales.

En lugar de listar delitos genéricos, debes centrarte en los riesgos tecnológicos que afectan a ACME:

- **Identifica 5 delitos informáticos específicos (basados en el Código Penal) en los que ACME podría incurrir como persona jurídica si sus sistemas fallan o son usados maliciosamente por empleados.**
 - Delitos contra la intimidad, allanamiento informático y otros delitos informáticos.
 - Estafas y fraudes.
 - Daños informáticos.
 - Delitos contra la propiedad intelectual e industrial, el mercado y los consumidores.
 - Blanqueo de capitales
- **Para cada delito, describe un escenario realista dentro de ACME (ej: *"Un administrador de sistemas descontento..."*).**
 - ❖ Delitos contra la intimidad, allanamiento informático y otros delitos informáticos.

Un trabajador entra sin autorización a los sistemas de clientes.

- ❖ Estafas y fraudes.

Podría haber una manipulación de sistemas en temas de facturación o desvío de dinero entre estos otros casos similares.

- ❖ Daños informáticos.

Un empleado podría borrar o alterar el sistema y provocar una caída en el sistema.

- ❖ Delitos contra la propiedad intelectual e industrial, el mercado y los consumidores.

El uso de usar software sin licencia por algunos trabajadores.

- ❖ Blanqueo de capitales

El uso de plataformas de ACME para hacer pagos fraudulentos.

Apartado 2: Matriz de Riesgo y Controles Mitigantes.

Con los 5 delitos identificados en el apartado anterior:

1. **Elabora una Matriz de Riesgo Penal: Asigna valores de Probabilidad (1-5) e Impacto (1-5) justificando brevemente por qué en cada caso.**

PROBABILIDAD	5					
	4					- Delitos contra la intimidad y allanamiento informático. - Daños informáticos.
	3			Delitos contra la propiedad intelectual	Estafas y fraudes	
	2					Blanqueo de capitales
	1					
		1	2	3	4	5
		IMPACTO				

2. **Propón una Medida de Mitigación TÉCNICA para cada uno.**

- ❖ Delitos contra la intimidad, allanamiento informático y otros delitos informáticos.

Para mitigar este punto propondría la grabación de sesiones y MFA obligatorio.

- ❖ Estafas y fraudes.

Para mitigar este punto propondría tener control de registros y alertas SIEM (Security Information and Event Manager) para modificaciones manuales.

❖ Daños informáticos.

Para mitigar este punto propondría tener backups, pero que estén aislados.

❖ Delitos contra la propiedad intelectual e industrial, el mercado y los consumidores.

Para mitigar este punto propondría tener un escaneo automático de licencias y el bloqueo de aplicaciones no autorizadas.

❖ Blanqueo de capitales

Para mitigar este punto propondría la monitorización de patrones sobre los sistemas de facturación y pagos. Tener alertas por ciclos repetitivos, importes...

- No valen respuestas genéricas.
- Debes proponer controles de ciberseguridad.

Apartado 3: Adecuación a la Ley 2/2023 y NIS2.

La Dirección quiere "cumplir con la ley gastando lo mínimo", pero tú debes asesorarles correctamente.

- 1. Canal de Denuncias: Redacta un pliego de 3 requisitos técnicos y funcionales que debe tener el software del Canal de Denuncias para cumplir rigurosamente con la Ley 2/2023 (anonimato, gestión de accesos, etc.). Explica por qué un correo electrónico normal (denuncias@acme.com) NO es válido.**

❖ **Requisito 1:** Anonimato real, es decir el sistema tiene que permitir denuncias sin registro, ni trazas ni nada parecido, cualquier fallo en algún punto anularía el anonimato

❖ **Requisito 2:** Control de accesos y segregación, es decir, acceso solo para el personal que sea designado, con MFA y que los registros de accesos no se puedan modificar, esto se hace porque tener solo un buzón compartido no asegura la confidencialidad.

- ❖ **Requisito 3:** Traza de evidencias, es decir, tener un control completo del ciclo de denuncias.

Un email no es valido como canal de denuncias, ya que no garantiza el anonimato, expone IP, metadatos... No asegura la cadena de custodia, ni gestiona plazos ni estados. No cumple la ley 2/2023 incumpliendo varios artículos de la misma, e incluso incurriría en sanción.

2. Responsabilidad Directiva (NIS2): Escribe un breve párrafo (máximo 10 líneas) dirigido al CEO explicando por qué la ciberseguridad ya no es solo un problema del departamento de informática, sino una responsabilidad legal directa de la alta dirección bajo la directiva NIS2.

Bajo la directiva NIS2, la ciberseguridad ya no es un asunto técnico y ahora pasa a ser una obligación legal de la dirección. La normativa exige que el CEO y el consejo estén alerta de la gestión de riesgo, que gestionen medidas de seguridad y se preocupen por su eficacia. En caso de algún incidente grave por algún incumplimiento de lo anteriormente mencionado la responsabilidad puede ser personal y acarrear sanciones económicas e incluso la inhabilitación. Delegar todo el peso en IT no exime de total responsabilidad, tener el control e informar es vital para generar un entorno seguro.